Nätverkssäkerhet

Föreläsning 3 – AAA

Authentication, Authorization and Accounting (AAA)

Kapitel 3

Hur har vi arbetat med autentisering tidigare?

```
R1(config)# enable secret cisco
R1(config)# ip domain-name dnlab.se
R1(config)# crypto key generate rsa general-keys modulus 1024
<…>
R1(config)# username sonny algorithm-type scrypt secret cisco123
R1(config)# line vty 0 4
R1(config-line)# login local
R1(config-line)# transport input ssh
R1(config-line)# exit
R1(config)# ip ssh version 2
R1(config)# ip ssh authentication-retries 2
R1(config)# ip ssh time-out 60
```

AAA

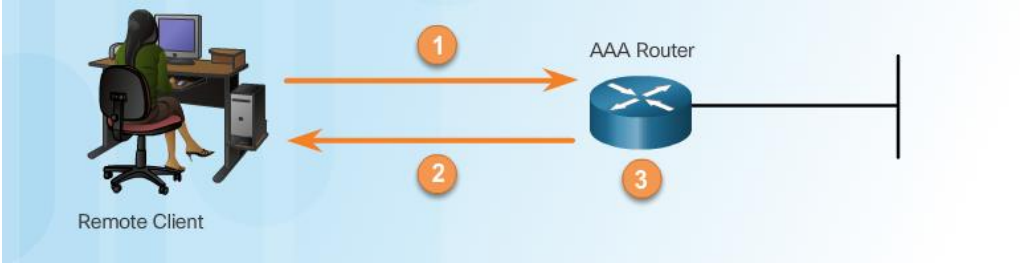
- Att implementera användarkonton, loggning, views, etc. på varje enhet är inte skalbart i längden
- För att stödja större nätverk bör man därför implementera AAA-tjänster som erbjuder:
  - Central styrning av konton och behörigheter
  - Möjlighet till fallback-lösningar
  - Loggning på användarbasis

Komponenter i AAA

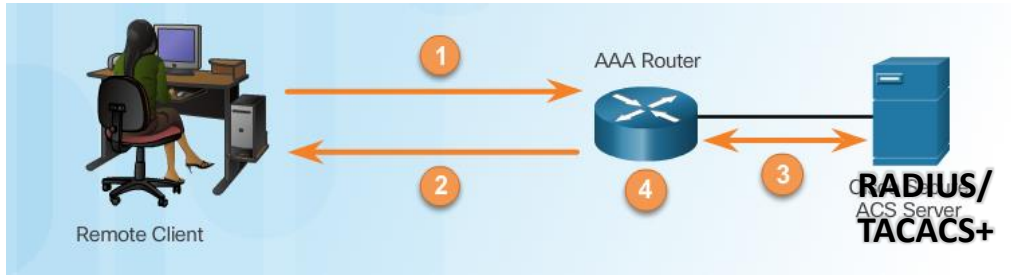
- **Authentication** – Vem är du?
  - Inloggning, grunden för all säkerhet. När man vet vem kan man bestämma rättigheter, logga osv
- **Authorization** – Vad får du göra?
  - När man vet VEM som är inloggad kan man bestämma VAD som får göras
    - Rättigheter i filsystem
    - Tillgängliga kommandon i Cisco IOS
- **Accounting** – Vad har du gjort?
  - När man vet VEM som är inloggad kan man logga VAD som har hänt
    - Även processer körs som en användare i t.ex. Windows Server

Authentication: Två varianter

Local AAA Authentication

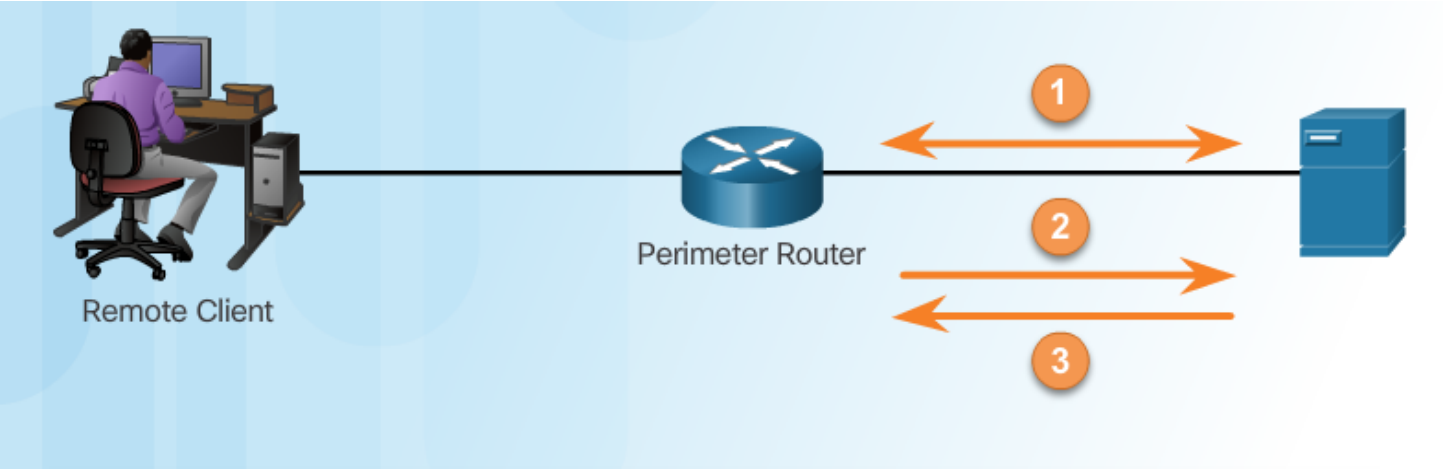


Server-Based AAA Authentication



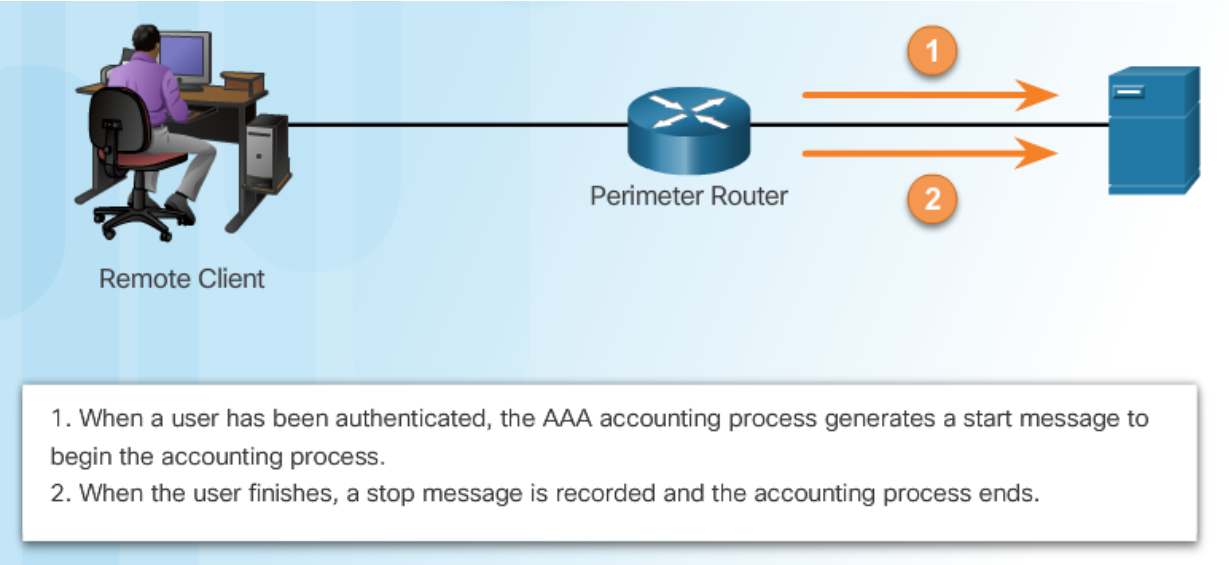
Authorization

- Bestämmer behörighetsnivå
  1. Vid inloggning (**authentication**) skapas en session mot AAA-servern
  2. När ett kommando körs, t.ex. **show run** testas behörigheten (**authorization**) mot AAA-servern
  3. AAA-servern svarar med PASS eller FAIL



Accounting

- Loggar användning av enheten, t.ex. vilka kommandon som har använts
  - **Connection** – Utgående anslutningar via exempelvis Telnet
  - **System** – Loggning på system-events, t.ex. reloads
  - **Command** – Loggning för kommandon på olika privilege-nivåer



Lokal AAA

Lokal AAA

- Det går att köra en inbyggd funktion för AAA som kan ersätta en enkel AAA-server
- Här används den lokala databasen för AAA-funktioner
- **Nackdel:** Databasen är **lokal**, dvs den måste skapas på varje switch/router/brandvägg.
- **Lösningen i stora nät:** RADIUS eller TACACS+ mot extern server, går även koppla mot AD (eller annan LDAP-lösning)

Authentication lists

Lokal databas, utan AAA-funktioner:

```
Router(config)# username sonnyfw privilege 15 algorithm-type scrypt secret cisco123
Router(config-line)# line vty 0 4
Router(config-line)# login local
```

Lokal databas, med AAA och authentication list default:

```
Router(config)# username sonnyfw privilege 15 algorithm-type scrypt secret cisco123
Router(config)# aaa new-model
Router(config)# aaa authentication login default local enable
```

Livelabb!

Vi ändrar i standard-listan

Första ”raden” i listan är local, dvs den lokala databasen

Om det inte finns någon lokal databas, matcha mot lösenordet för enable

Authentication lists

- När AAA aktiveras läggs en lista kallad ”default” på alla interface. Denna använder den lokala databasen som standard
- Default-listan kan konfigureras om, alternativt kan man göra en ny lista med eget namn
- Flera listor kan skapas, man kan använda olika listor för olika interface, exempelvis:
  - VTY: `login authentication REMOTE_ACCESS`
  - CONSOLE: `login authentication CON_ACCESS`

Authentication lists

Lokal databas, med AAA och namngiven authentication lists:

```
Router(config)# aaa authentication login MYLIST local enable
Router(config-line)# line vty 0 4
Router(config-line)# login authentication MYLIST
```

Namnet på listan är MYLIST

Första ”raden” i listan är local, dvs den lokala databasen

Om det misslyckas, matcha mot lösenordet för enable

Livelabb!

Authentication lists

```
Core-VSS(config)# aaa authentication login TESTLIST ?
  cache        Use Cached-group
  enable       Use enable password for authentication.
  group        Use Server-group
  krb5         Use Kerberos 5 authentication.
  krb5-telnet  Allow logins only if already authenticated via
               Kerberos V Telnet.
  line         Use line password for authentication.
  local        Use local username authentication.
  local-case   Use case-sensitive local username authentication.
  none         NO authentication.
```

Authentication lists - exempel

```
R1(config)# username sonnyfw algorithm-type scrypt secret cisco123
R1(config)# aaa new-model
R1(config)# aaa authentication login default local-case enable
R1(config)# aaa authentication login REMOTE_ACCESS local-case
R1(config)# line vty 0 4
R1(config-line)# login authentication REMOTE_ACCESS
```

Följande händer:

- Listan ”default” konfigureras med lokala databasen i skiftlägeskänsligt läge samt enable
- En ny lista skapas kallad REMOTE_ACCESS som endast går mot lokala databasen i skiftlägeskänsligt läge
- Listan REMOTE_ACCESS konfigureras för VTY. Alla inloggningar mot VTY kommer alltså köras mot listan
- Inloggning på andra sätt, t.ex. via Console, använder default-listan

Felsökning inom lokal AAA

- debug aaa authentication
- show aaa sessions

```
R1# debug aaa authentication
113123: Feb 4 10:11:19.305 CST: AAA/MEMORY: create_user (0x619C4940) user=''ruser=''
        port='tty1' rem_addr='async/81560' authen_type=ASCII service=LOGIN priv=1
113124: Feb 4 10:11:19.305 CST: AAA/AUTHEN/START (2784097690): port='tty1' list=''
        action=LOGIN service=LOGIN
113125: Feb 4 10:11:19.305 CST: AAA/AUTHEN/START (2784097690): using "default" list
113126: Feb 4 10:11:19.305 CST: AAA/AUTHEN/START (2784097690): Method=LOCAL
113127: Feb 4 10:11:19.305 CST: AAA/AUTHEN (2784097690): status = GETUSER
113128: Feb 4 10:11:26.305 CST: AAA/AUTHEN/CONT (2784097690): continue_login
        (user='(undef)')
113129: Feb 4 10:11:26.305 CST: AAA/AUTHEN (2784097690): status = GETUSER
113130: Feb 4 10:11:26.305 CST: AAA/AUTHEN/CONT (2784097690): Method=LOCAL
113131: Feb 4 10:11:26.305 CST: AAA/AUTHEN (2784097690): status = GETPASS
113132: Feb 4 10:11:28.145 CST: AAA/AUTHEN/CONT (2784097690): continue_login
        (user='diallocal')
113133: Feb 4 10:11:28.145 CST: AAA/AUTHEN (2784097690): status = GETPASS
113134: Feb 4 10:11:28.145 CST: AAA/AUTHEN/CONT (2784097690): Method=LOCAL
113135: Feb 4 10:11:28.145 CST: AAA/AUTHEN (2784097690): status = PASS
```

Livelabb!

Authorization

- Handlar om behörighet, t.ex. att vi automatiskt kommer till *privileged exec mode* (Router#)
- Lokal:

```
R1(config)# aaa authorization exec default local
```

  - Inte på konsol!

```
R1(config)# aaa authorization console
```

  - Även på konsol!

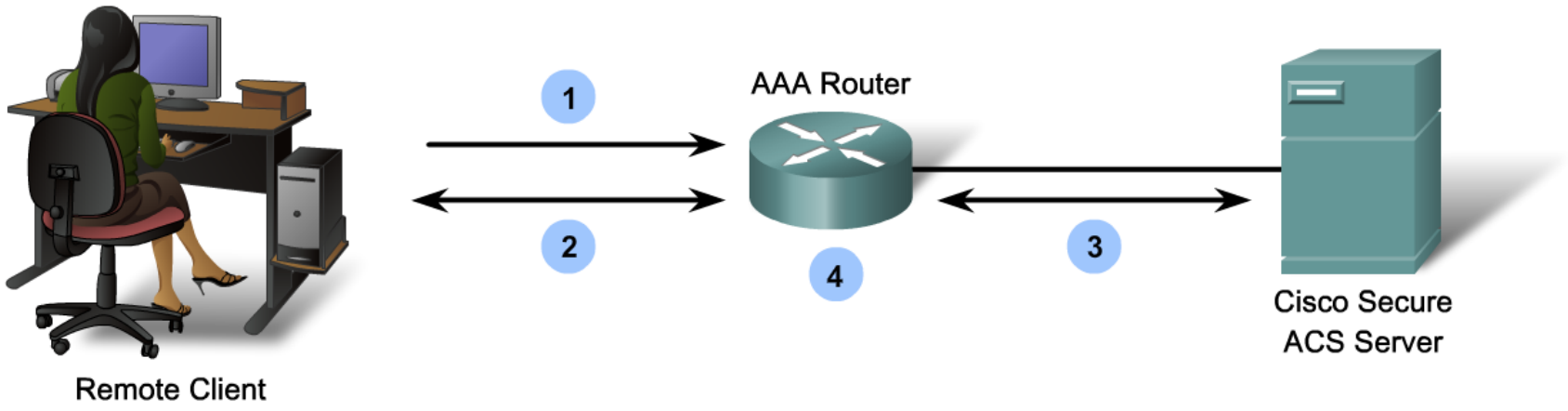
Livelabb!

- Viktigt att det finns ett användarnamn med privilege level 15!

Serverbaserad AAA

Authentication med server

- Två protokoll för kommunikation med server
  - **TACACS+** (Öppen Cisco-standard)
  - **RADIUS** (Öppen standard)



TACACS+ & RADIUS

- **TACACS+**
  - Öppen Cisco-standard
  - Krypterar hela paketet
  - Skiljer på Authentication och Authorization
  - TCP
  - Accounting finns
- **RADIUS**
  - Öppen standard
  - Krypterar endast lösenordet
  - Kombinerar Authentication och Authorization
  - UDP
  - Avancerade funktioner för accounting finns

Konfigurera serverbaserad AAA

Livelabb!

- **TACACS+**

```
R1(config)# aaa authentication login default group tacacs+ local
R1(config)# tacacs server TEST-tacacs
R1(config-server-tacacs)# address ipv4 192.168.1.100
R1(config-server-tacacs)# single-connection (ser till att samma TCP-session återanvänds)
R1(config-server-tacacs)# key cisco123
```

- **RADIUS**

```
R1(config)# aaa authentication login default group radius local
R1(config)# radius server TEST-radius
R1(config-radius-server)# address ipv4 192.168.1.101 auth-port 1812 acct-port 1813
R1(config-radius-server)# key cisco123
```

Installation av WinRADIUS

Livelabb!

- I labben ska ni använda er av WinRadius
- Finns på ftp.dnlab.se under WinRadius
  - Öppna .exe-filen som admin och gå in i Settings -> Database -> Configure ODBC…
  - Starta om
  - Skapa användare (max 5)
  - Öppna upp aktuella portar (t.ex. 1812), eller stäng av brandväggen
  - Ligger ett standardlösenord (WinRadius)

Felsökning av TACACS+ och RADIUS

```
R1# debug tacacs
TACACS access control debugging is on
R1#

13:53:35: TAC+: Opening TCP/IP connection to 192.168.1.101 using source 192.48.0.79
13:53:35: TAC+: Sending TCP/IP packet number 416942312-1 to 192.168.1.101 (AUTHEN/START)
13:53:35: TAC+: Receiving TCP/IP packet number 416942312-2 from 192.168.60.15
13:53:35: TAC+ (416942312): received authen response status = GETUSER
13:53:37: TAC+: send AUTHEN/CONT packet
13:53:37: TAC+: Sending TCP/IP packet number 416942312-3 to 192.168.1.101 (AUTHEN/CONT)
13:53:37: TAC+: Receiving TCP/IP packet number 416942312-4 from 192.168.60.15
13:53:37: TAC+ (416942312): received authen response status = GETPASS
13:53:38: TAC+: send AUTHEN/CONT packet
13:53:38: TAC+: Sending TCP/IP packet number 416942312-5 to 192.168.1.101 (AUTHEN/CONT)
13:53:38: TAC+: Receiving TCP/IP packet number 416942312-6 from 192.168.60.15
13:53:38: TAC+ (416942312): received authen response status = FAIL
13:53:40: TAC+: Closing TCP/IP connection to 192.168.60.15
```

```
R1# debug radius ?
  accounting      RADIUS accounting packets only
  authentication  RADIUS authentication packets only
  brief           Only I/O transactions are recorded
  elog            RADIUS event logging
  failover        Packets sent upon fail-over
  local-server    Local RADIUS server
  retransmit      Retransmission of packets
  verbose         Include non essential RADIUS debugs
  <cr>
```

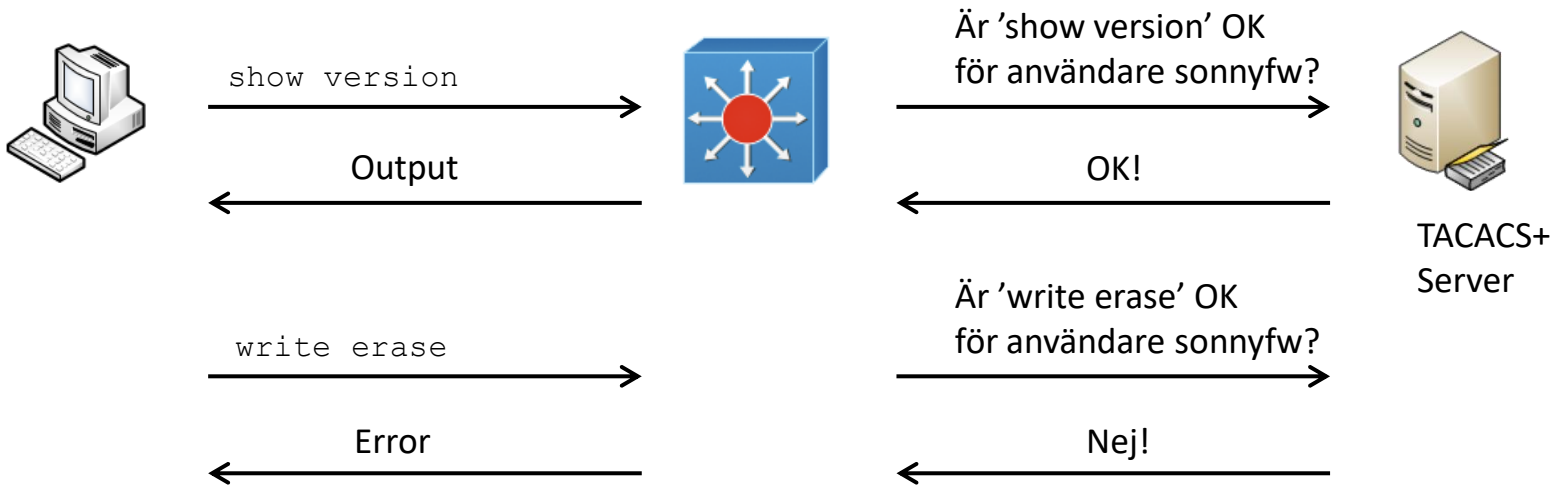
Authorization via server

- Authorization har tre ”service types”:
  - **Network** (Behörighet att starta/stoppa nätverksprotokoll)
  - **Exec** (Tillåtelse att logga in via terminalen)
  - **Commands** (Användning av specifika kommandon)
- Konfiguration:

```
R1(config)# aaa authorization exec default group tacacs+
```

Authorization via server

- TACACS+ kan kontrollera vilka kommandon ett konto får köra
  - **Kom ihåg:** RADIUS skiljer inte på Authentication och Authorization



Accounting via server

- Accounting = Loggning

```
R1(config)# aaa accounting {network | exec | connection} {default | list-name}
{start-stop | stop-only | none} method1...[method4]

R1(config)# aaa accounting connection default start-stop group tacacs+
```

Anslutningar till enheten

Namn på lista

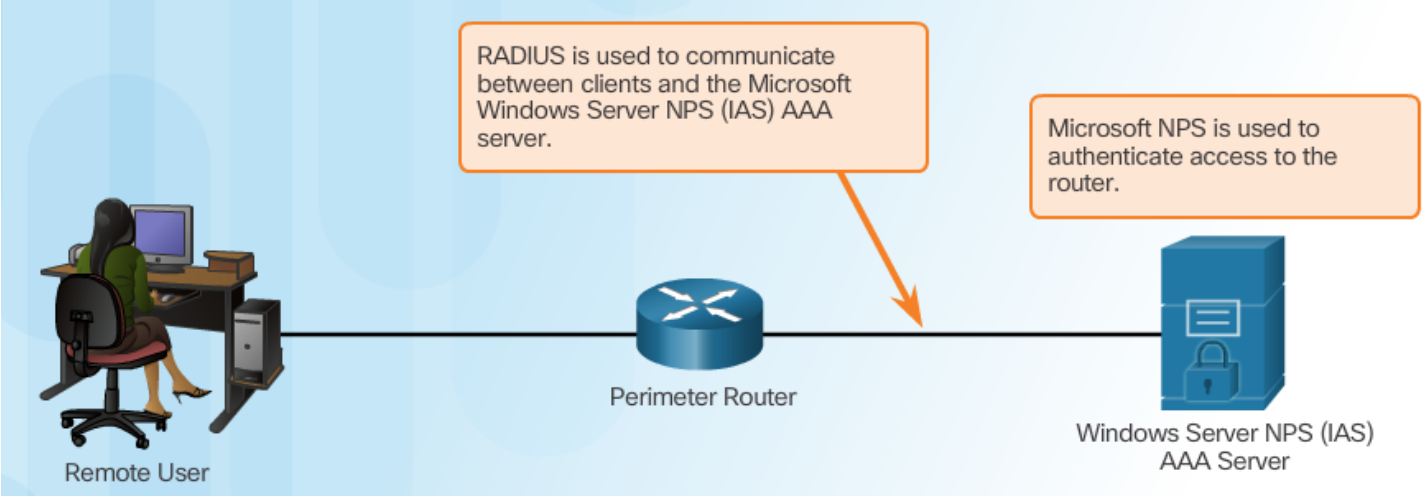
Logga när tjänsten startas eller stoppas

Logga till TACACS+

Livelabb!

AAA med Active Directory

- Windows Server **Network Policy Server (NPS)**
  - Hette tidigare **Internet Authentication Service (IAS)**
- Gör att vi kan sätta igång funktioner för RADIUS på vår AD-miljö
- Det går även att koppla ihop **Cisco Secure Access Control System (ACS)** med AD

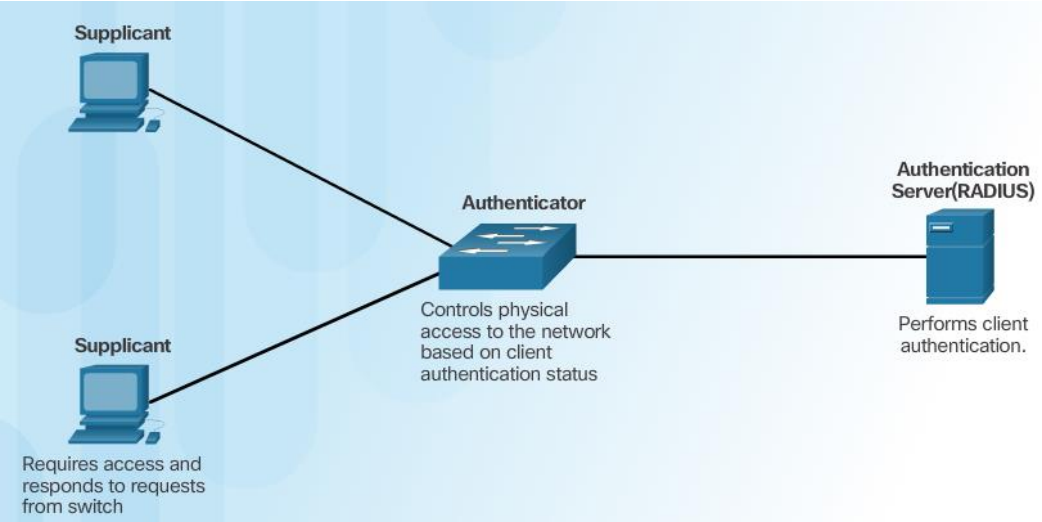


Säkra portarna i lokala nätverk

802.1x

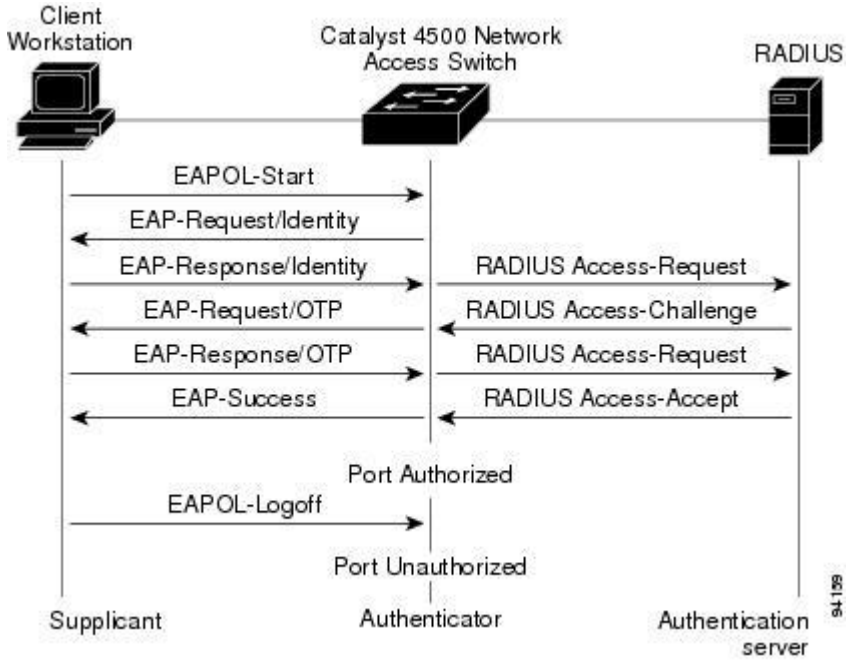
Säkra portarna i lokala nätverk (802.1x)

- **802.1x** gör att AAA kan användas på det lokala nätverket
- Standarden definierar tre olika roller
  - **Supplicant** (t.ex. en klient)
  - **Authenticator** (t.ex. en switch)
  - **Authentication server** (t.ex. en AAA-server)

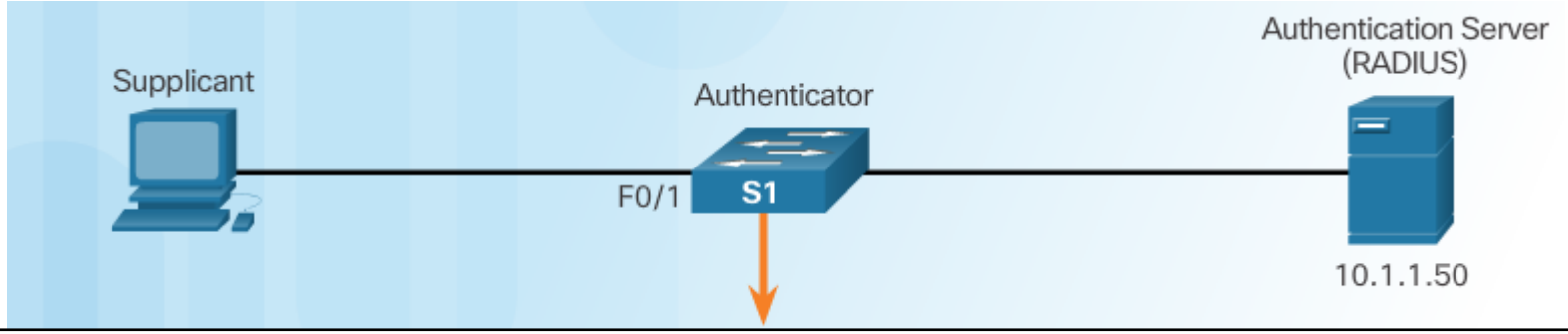


802.1x-paket

- Mellan **Supplicant** och **Authenticator** skickas trafiken med EAP/EAPoL
- Mellan **Authenticator** och **Authentication Server** skickas trafiken med RADIUS



Konfiguration




```
S1(config)# aaa authentication dot1x default group radius local
S1(config)# dot1x system-auth-control
S1(config)# interface fa0/1
S1(config-if)# switchport mode access
S1(config-if)# dot1x pae authenticator
S1(config-if)# authentication port-control auto
```

- **Supplicant** måste också vara konfigurerad för 802.1x

Verifiera

```
S1(config)# show dot1x interface fa0/1 details
Dot1x Info for FastEthernet0/1
 -----------------------------------
 PAE                         = AUTHENTICATOR
 PortControl                 = AUTO
 ControlDirection            = Both
 HostMode                    = SINGLE_HOST
 ReAuthentication            = Disabled
 QuietPeriod                 = 60
 ServerTimeout               = 30
 SuppTimeout                 = 30
 ReAuthPeriod                = 3600 (Locally configured)
 ReAuthMax                   = 2
 MaxReq                      = 2
 TxPeriod                    = 30
 RateLimitPeriod             = 0

 Dot1x Authenticator Client List
 -------------------------------
 Supplicant                  = 1000.0000.2e00
         Auth SM State       = AUTHENTICATED
         Auth BEND SM Stat   = IDLE
 Port Status                 = AUTHORIZED

 Authentication Method       = Dot1x
 Authorized By               = Authentication Server
 Vlan Policy                 = N/A
```

kahoot.it

JÖNKÖPING UNIVERSITY

School of Engineering